

Cybersecurity Due Diligence — Executive Summary

Target: NovaPay Technologies • Acquirer: Meridian Financial Group
Deal value: \$85M • Assessment window: 4 weeks • Prepared for: Meridian Board & Executive Team

OVERALL ACQUISITION RISK RATING: HIGH

1. Executive Summary

Meridian Financial Group engaged its security team to assess the cybersecurity posture of NovaPay Technologies ahead of the proposed \$85 million acquisition. NovaPay processes payments for 200,000 small businesses, which places cardholder data and PCI DSS compliance at the center of this review. The assessment ran over four weeks and drew on NovaPay's vendor security questionnaire, its technology inventory, a partial network diagram, and its SOC 2 report.

Based on our assessment, NovaPay presents a High cybersecurity risk at current state, with two Critical findings that should be resolved as pre-close conditions. NovaPay is a capable payments business, but it has grown faster than its security function. It operates with no dedicated security team, incomplete multi-factor authentication, unmonitored endpoints, a legacy off-cloud database of historical transactions, and no incident-response capability. None of these gaps is unusual for a startup of this size, and all are remediable. The risk to Meridian is manageable provided the two Critical items are fixed before close and a phased remediation plan is funded for the first six months after.

2. Scope and Methodology

We reviewed NovaPay's completed vendor security questionnaire, its documented technology stack, the partial network diagram provided, and its 18-month-old SOC 2 Type I report. We assessed the environment against **NIST CSF 2.0** across all six functions (Govern, Identify, Protect, Detect, Respond, Recover) and benchmarked specific controls against **CIS Controls v8**. Incident-response recommendations reference **NIST SP 800-61**. Each gap was scored for maturity (1-5) and translated into a risk-register entry using likelihood x impact scoring. This was a documentation-based due diligence review, not a technical penetration test.

3. Summary of Findings

ID	Title	Severity	NIST CSF Area
F-001	Incomplete MFA deployment (60% coverage)	Critical	Protect > Identity Mgmt
F-002	No endpoint detection & response (EDR)	Critical	Protect > Platform Security
F-003	Legacy Oracle DB outside cloud security scope	High	Identify > Asset Mgmt
F-005	No incident response plan	High	Respond > IR Management
F-006	No vulnerability management program	High	Identify > Risk Assessment

ID	Title	Severity	NIST CSF Area
F-004	SOC 2 Type I only, no continuous assurance	Medium	Govern > Risk Mgmt
F-007	Public GitHub repos / secrets exposure	Medium	Detect > Continuous Monitoring
F-008	No security function (single IT admin)	Medium	Govern > Roles & Responsibilities

Severity: Red = Critical, Orange = High, Yellow = Medium.

4. Risk Register Highlights — Top 3 Risks

R-001 (Score 20, Critical). Staff can reach payment systems without multi-factor authentication, so one stolen password could open the door to a cardholder-data breach and PCI penalties.

R-002 (Score 20, Critical). Company laptops have no threat-detection software, so an attacker who compromises one could move into the payment systems and operate unnoticed for a long time.

R-006 (Score 16, High). There is no program to find and fix software weaknesses, so known, exploitable flaws could sit unpatched in an internet-facing payment platform.

5. Recommendations

Pre-close conditions (resolve before signing):

- 1 Complete the Okta MFA rollout to 100% of staff and all administrative access (R-001).
- 2 Sign an incident-response retainer with a third-party firm to cap breach liability from day one (R-005).
- 3 Kick off the SOC 2 Type II audit so assurance work begins before close (R-004).

30-90 days post-close (quick wins):

- 1 Deploy EDR to all Windows endpoints (R-002).
- 2 Bring the legacy Oracle database into inventory; confirm encryption at rest and apply CIS hardening (R-003).
- 3 Enable GitHub secrets scanning and rotate any exposed credentials (R-007).
- 4 Stand up vulnerability scanning and a patch SLA (R-006).

90-180 days post-close (strategic):

- 1 Hire a dedicated security lead or embed a Meridian resource; establish separation of duties (R-008).
- 2 Build and test a formal IR plan aligned to NIST SP 800-61 (R-005).
- 3 Commission a penetration test of the Kubernetes payment environment.

6. Overall Acquisition Risk Rating

HIGH. NovaPay carries two Critical and three High risks concentrated in identity, endpoint security, and incident readiness — all material for a PCI-regulated payments business. The rating is High rather than Critical because every gap is well understood and remediable on a clear timeline, and the two Critical items can be closed cheaply and quickly before the deal completes. We recommend Meridian proceed with the acquisition conditional on the pre-close items above, with the phased remediation plan funded and owned from day one.

Fictional scenario prepared for a cybersecurity due-diligence portfolio project. All findings and data are illustrative.